

# Research 05 Data Identity Privacy Sop

Source type: DubboEwaste repository document

Repository path: docs/RESEARCH-05-DATA-IDENTITY-PRIVACY-SOP.md

Source commit: c2103b6090c8

Pack generated: 6 October 2026

## Research 05: Data, identity, locks and privacy SOP

Research date: 2 October 2026 (AEST)

Gap covered: codexGAPS.md section 6, plus the identity and data exceptions that affect sections 2, 7, 11, 12 and 15.

Status: operational design complete; legal/privacy applicability, insurer acceptance and the exact sanitisation toolchain still require adviser confirmation and bench validation.

### Executive decision

DubboEwaste should treat every accepted device as two separate assets:

1. the physical item that may be repaired, reused, sold or recycled; and
2. the identity/data state that may prevent release or create harm.

No device should move to retail, donation or parts release merely because it boots, has been factory-reset, or appears empty. The release gate is:

- authority proven
- identity/lock state resolved
- storage and removable media identified
- sanitisation method selected for that media and risk
- sanitisation executed and verified
- evidence recorded
- public photos/listing reviewed for data leakage

If any step cannot be completed, route the device to quarantine, owner/administrator resolution, specialist data destruction, or downstream recycling. Do not accept passwords or ask a donor to disclose them.

### 1. What current primary sources establish

#### ACSC: ordinary disposal is not a high-assurance sanitisation certificate

The Australian Cyber Security Centre advises backing up wanted data, factory-resetting the device and removing removable media before selling, recycling or giving away a computer, phone, tablet, console or smart device. Its guidance also warns that sensitive information may still be recoverable and recommends a data-destruction service or IT professional for particularly sensitive data.

Sources:

- ACSC: How to dispose of your device securely (<https://www.cyber.gov.au/protect-yourself/securing-your-device/how-secure-your-device/how-dispose-your-device-securely>)
- ACSC: Small Business Cyber Security Guide ([https://www.cyber.gov.au/sites/default/files/2023-07/acsc\\_small\\_business\\_cyber\\_security\\_guide.pdf](https://www.cyber.gov.au/sites/default/files/2023-07/acsc_small_business_cyber_security_guide.pdf))

Operational interpretation: “factory reset completed” is a consumer handover result, not a universal business sanitisation claim. The tracker must distinguish factory\_reset, sanitised, verified, and destroyed.

## **NIST SP 800-88 Rev. 2: choose a method by media and risk**

NIST published SP 800-88 Rev. 2 in September 2025, superseding Rev. 1. It defines media sanitisation as making access to target data infeasible for the relevant level of effort and frames sanitisation as a programme decision based on information sensitivity, media type, technique and verification. The latest publication should be the reference point for commercial claims rather than an old Rev. 1-only checklist.

Source:

- NIST SP 800-88 Rev. 2 (<https://csrc.nist.gov/pubs/sp/800/88/r2/final>)

Operational interpretation: a technician must first identify the storage medium and its state. A generic multi-pass overwrite instruction is not a safe universal rule for modern SSDs, flash storage, encrypted devices, failed drives, phones or appliances.

## **OAIC: protect, destroy/de-identify, and document**

OAIC guidance on Australian Privacy Principle 11 says entities covered by the Privacy Act must take reasonable steps to protect personal information from misuse, interference, loss, unauthorised access, modification and disclosure. When personal information is no longer needed, reasonable steps to destroy or de-identify it apply; the guidance discusses technical and organisational measures, documentation, access controls, logs and audit trails. It also explains that a small business may still be covered regardless of turnover in situations such as health services, trading in personal information, Commonwealth contracting, credit activity or TFN handling.

Sources:

- OAIC: APP 11 security of personal information (<https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-guidelines/chapter-11-app-11-security-of-personal-information>)
- OAIC: Small business (<https://www.oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/organisations/small-business>)
- OAIC: Guide to securing personal information (<https://www.oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/handling-personal-information/guide-to-securing-personal-information>)

Operational interpretation: the operator must not rely on the “small business exemption” as a reason to retain unprotected donor information. Use the same minimum controls for every intake; obtain advice about when the Privacy Act, a contract or another law applies.

## **OAIC: suspected breach response**

OAIC’s current breach guidance uses four steps: contain, assess, notify and review. The Notifiable Data Breaches scheme applies to covered entities where an eligible breach is likely to cause serious harm and remedial action has not prevented that risk. The operator should escalate immediately rather than deciding informally that a device exposure is “probably harmless.”

Sources:

- OAIC: Responding to data breaches (<https://www.oaic.gov.au/privacy/notifiable-data-breaches/preventing-preparing-for-and-responding-to-data-breaches/data-breach-preparation-and-response/part-3-responding-to-data-breaches-four-key-steps>)
- OAIC: Preparing a data breach response plan (<https://www.oaic.gov.au/privacy/notifiable-data-breaches/preventing-preparing-for-and-responding-to-data-breaches/data-breach-preparation-and-response/part-2-preparing>)

a-data-breach-response-plan)

- OAIC: NDB scheme (<https://www.oaic.gov.au/privacy/notifiable-data-breaches/preventing-preparing-for-and-re-sponding-to-data-breaches/data-breach-preparation-and-response/part-4-notifiable-data-breach-ndb-scheme>)

## **Platform-owner lock rules are not optional refurbishment steps**

Apple says Activation Lock should be removed before a device is sold, given away or traded, and provides an owner/web removal path for an offline device. Microsoft says a device permanently leaving an organisation should be deregistered from Windows Autopilot, with Intune, Autopilot and tenant cleanup in the right order; simply deleting one record may leave another association. These are owner or administrator actions, not tasks for a reseller to bypass.

Sources:

- Apple: Remove Activation Lock (<https://support.apple.com/en-ie/108934>)
- Apple: Remove a device from Find My (<https://support.apple.com/en-mide/guide/iphone/ipha94b7686e/ios>)
- Microsoft: Windows Autopilot registration and deregistration (<https://learn.microsoft.com/en-us/autopilot/registration-overview>)
- Microsoft: Remove Windows Autopilot device association (<https://learn.microsoft.com/en-us/autopilot/device-preparation/device-association/remove-association>)

Operational interpretation: a lock is an ownership/administration exception, not a repair challenge. Do not use bypass tools, request passwords, or list a locked device as “tested.”

## **2. Identity and authority at the front door**

### **2.1 Minimum donor declaration**

For a consumer or sole trader, record:

- donor name and preferred contact;
- a plain statement that the donor owns the device or is authorised to dispose of it;
- make/model and visible serial/IMEI reference;
- whether the device contains personal, business, health, financial, school or customer data;
- whether the donor has backed up data and removed accounts;
- the route requested: reuse, repair, parts or recycling;
- permission to test, reset, sanitise, disassemble and route the item according to the signed terms.

For a business, school, charity or MSP, add:

- organisation legal/trading name and contact;
- authorised decision-maker and role;
- disposal authority or work order/reference;
- whether the organisation requires a certificate, witnessed destruction, chain-of-custody record or return of failed media;
- who owns any embedded data and who can answer an account/MDM/Autopilot exception;
- downstream requirements and retention period agreed in writing.

This is evidence of authority, not proof of title. If provenance is suspicious, the device is asset-tagged to another organisation, serials are defaced, or the story does not fit, refuse or hold for clarification.

## 2.2 No-password policy

The operator must never request or record:

- Apple Account, Google, Microsoft, Samsung or social-account passwords;
- Windows, BIOS, UEFI, MDM or cloud-admin credentials;
- SIM PINs, banking PINs, recovery codes or two-factor codes.

The owner or authorised administrator performs account removal while the device remains in their control, or uses the vendor's documented remote removal path. The operator records only the result, date, device identifier and evidence reference.

If the donor says "you can keep my password," decline and explain that the password is not needed and must not be shared. If access is required to recover data, return the device to the owner or refer them to an authorised data-recovery provider.

## 2.3 Organisation handover script

Use this before accepting a business lot:

"Please confirm that your organisation owns or is authorised to dispose of these devices, and that you have authority to approve testing, account removal, sanitisation, disassembly and recycling. Please identify the administrator who can remove Apple Activation Lock, Android/Google protection, MDM, Microsoft Autopilot or BIOS restrictions. We will not accept passwords. If sanitisation fails or the device cannot be unlocked, do you want the media returned, destroyed by an approved provider, or held pending written instructions?"

The signed response should name the organisation's contact and the requested failure route. A verbal promise that "IT has wiped everything" does not remove the need for an incoming media decision, because the operator may still receive residual data.

## 3. Intake state machine

State | Meaning | Allowed action | Exit evidence

RECEIVED-QUARANTINE | Authority or data state not yet established | Label, photograph exterior, isolate from normal stock | signed intake or refusal

IDENTITY-CHECK | Serial/IMEI/asset tags and provenance being checked | Inspect without bypassing locks | identity/provenance note

OWNER-ACTION | Account, MDM or tenant removal needed | Return to owner/admin; no password capture | owner/admin confirmation and clean OOB result

DATA-HOLD | Storage may contain data and sanitisation plan is not selected | No resale, parts release or network connection | media inventory and approved method

SANITISE | Approved method being run | Controlled bench, logged operator and tool/version | certificate/log and verification

REPAIR-RETEST | Physical work may affect the storage/identity state | Repair, then repeat lock and sanitisation checks | updated test record

RELEASED | Data and identity gates passed | List, donate or move to approved downstream route | asset release record

DESTROY-REFER | Failed/unknown media or high-risk data | Approved destruction/referral; retain custody | destruction/return evidence

REFUSED-RETURN | Authority or safety cannot be resolved | Do not retain or process | refusal reason and handback record

Never skip directly from RECEIVED-QUARANTINE to RELEASED.

## 4. Media and device decision matrix

The matrix is a triage aid, not a substitute for NIST-based risk selection or specialist advice.

Device/media | Minimum identification | Normal reuse path | Exception route

SATA HDD | model, serial, health, capacity, whether readable | Sanitisation method suitable for the sensitivity; verify result; re-test | failed/read-only/uncertain drive to physical destruction or approved provider

SATA/NVMe SSD | model, firmware, health, encryption state, capacity | Use vendor-supported sanitize/crypto-erase path where appropriate; capture tool output and verification | failed controller, inaccessible media or high-sensitivity data to destruction/provider

USB/SD/SIM/removable media | remove and inventory separately | Owner retains it, or sanitise/destroy separately | unknown media is not left in a listed device

Apple iPhone/iPad/Mac | serial/IMEI, Find My/Activation Lock, MDM/ABM state | Owner removes account/lock; erase using Apple-supported process; confirm new-user setup | Activation Lock/MDM unresolved, damaged storage or owner unavailable: return/referral/parts route only

Android phone/tablet | IMEI, Google/Samsung account state, FRP/MDM, carrier status | Owner removes account; supported erase; verify setup without prior account | FRP/MDM/unknown account: no resale or bypass; return/referral/parts

Windows laptop/desktop | serial, BIOS/UEFI password, BitLocker/recovery state, Autopilot/Intune status | Organisation deregisters tenant/MDM; approved media sanitisation; clean OOBE test | Autopilot/MDM/BIOS unresolved or storage inaccessible: quarantine/return/destruction

Chromebook | serial, enterprise enrolment, Google admin state, storage type | Admin unenrols; Powerwash; verify unenrolled OOBE | enterprise-enrolled or admin unavailable: no resale

Console | account unlink, user data, internal/expandable storage, parental controls | Owner signs out/unlinks; supported reset; remove cards/drives; verify setup | inaccessible account, removable storage or cloud lock: hold/return/referral

Router/NAS/switch | config/NVRAM, admin accounts, certificates, logs, internal storage | Owner/export decision; reset and verify; clear configs and removable media | business credentials, stored keys or unreadable storage: specialist destruction/referral

Printer/MFP | address book, scan-to-email credentials, fax history, internal disk/USB | Admin reset plus storage sanitisation; verify no retained jobs/credentials | office MFP disk/credentials unknown: do not release without specialist process

Smart TV/IoT/camera/speaker | accounts, Wi-Fi, microphones/cameras, cloud registration | Owner unlinks; factory reset; remove cards; verify onboarding | cloud account or privacy state unclear: hold/return/parts route

Camera/drone | SD card, account/cloud link, flight logs, GPS data | Remove media; owner unlink/reset; verify | unknown card/account or personal location history: hold/referral

## 5. Sanitisation evidence record

Every media-bearing asset should have a private record containing:

```
asset_id, intake_id, owner_or_org, authority_reference,
device_type, make_model, serial_or_imei_hash,
storage_type, storage_model, capacity, media_serial_hash,
encryption_state, lock_state_before, account_state_before,
sanitisation_method, standard_or_policy_reference,
tool_name, tool_version, operator, start_time, end_time,
result, verification_method, verification_result,
exceptions, downstream_route, certificate_id, reviewer
```

Public-facing documents should contain only the minimum information needed to identify the certificate. Do not publish full serials, IMEIs, donor names, addresses, screenshots of accounts, Wi-Fi names or residual files.

## Verification levels

Level | Use | Evidence | Public wording

RESET | low-risk consumer handover where appropriate | supported reset completed and clean setup screen | “factory-reset; no high-assurance sanitisation claim”

SANITISED-VERIFIED | media cleared using approved method | tool result, media identity, verification and reviewer | “sanitised under the stated procedure”

DESTROYED-VERIFIED | media cannot be safely reused or risk requires destruction | provider/destruction record and custody trail | “storage media destroyed; device may be sold only if no other data-bearing media remains”

UNKNOWN-HOLD | method or result cannot be proved | exception record | not for reuse or sale

Do not describe a reset as “NIST compliant” unless the complete process, media decision, verification and documentation have actually been reviewed against the applicable revision and customer requirement.

## 6. Account and lock exception playbooks

### Apple

1. Record the device serial/IMEI privately.
2. Ask the owner to turn off Find My/Activation Lock on the device or remove the device through their Apple account while it is offline.
3. For an organisation-owned device, route to the organisation's IT/Apple administrator; do not accept a personal account password.
4. Erase using Apple-supported steps.
5. Start setup far enough to confirm the device does not ask for the previous owner's account.
6. If the previous account is requested, quarantine and return/refer. Apple's support path may require proof of purchase; a reseller cannot manufacture that proof.

### Android

1. Record IMEI and model privately.
2. Owner removes Google/Samsung and other device-management accounts using supported device settings.
3. Perform the supported erase and verify that setup does not request the previous account.
4. If Factory Reset Protection appears, do not bypass it. Return to the owner/admin or route to parts/recycling under the agreed data decision.

### Windows and Microsoft management

1. Record serial and asset reference.
2. Ask the organisation's administrator to remove the device from MDM/Intune and deregister it from Autopilot in the documented order.
3. Do not infer that a local reset removed the tenant. Microsoft's Autopilot Reset preserves Entra and Intune management connections.
4. At the bench, run a clean OOBE test without joining the operator's personal accounts.
5. If the organisation cannot prove deregistration, do not sell as a normal end-user device.

### BIOS/UEFI/Computrace/enterprise locks

Record the exact prompt and refer to the manufacturer or owner organisation. Do not use password-removal, EEPROM or persistence-bypass techniques on property of uncertain provenance. An uneconomic locked device may be a lawful parts/recycling route, but only after storage/data handling is resolved.

## 7. Data exposure rules during testing

- Use an isolated test network or offline mode until the device has been assessed; do not connect unknown devices to the home LAN.
- Never open donor files, photos, browser history, email, cloud drives or password stores as part of ordinary triage.
- If a device boots into a live user session, stop and ask the owner to perform the handover step, or power down and use an approved sanitisation path.
- If personal or business data is visible accidentally, stop, do not copy or photograph it, record only the minimum incident facts, isolate the device and notify the designated privacy contact.
- Do not upload donor files to repair tools, cloud diagnostics, AI services or online scanners.

- Use synthetic test data when validating trackers, certificates, scripts and listing templates.

## 8. Public photos and listing privacy

Before publishing a listing, inspect every image for:

- serial numbers, IMEIs, asset tags or barcode labels;
- names, email addresses, usernames, school/company logos or employee identifiers;
- Wi-Fi SSIDs, IP addresses, QR codes, recovery codes or device-management screens;
- faces, house numbers, vehicle registrations, geolocation clues or reflections;
- browser tabs, notifications, file names, desktop documents or account avatars;
- diagnostic screenshots that expose hardware hashes, tenant IDs, licence keys or certificates.

Use a separate private evidence photo and public listing photo set. Redaction by cropping is safer than drawing over an identifier in an editor that may preserve the original layer or metadata.

## 9. Intake records, retention and deletion

The public repository must never contain donor/buyer personal information, full serial/IMEI lists, certificates containing personal data, marketplace messages, payment exports, home addresses or raw device images.

Minimum local controls:

1. Store the working ledger and evidence folder on an encrypted account/device.
2. Restrict access to the operator and named authorised helpers.
3. Use asset IDs in filenames rather than donor names.
4. Hash or partially redact serials/IMEIs in ordinary reports; store the lookup table separately.
5. Keep certificates, owner authority and complaint evidence only as long as needed for the agreed business, legal, tax, safety or partner purpose.
6. Delete or securely destroy duplicates, exports, thumbnails, cloud recycle-bin copies and old backups when the retention period expires.
7. Document who deleted what, when and by which method.

Do not choose a fixed retention period by guesswork. Ask the accountant, insurer, consumer-law adviser and relevant partner what must be retained. Where a deletion request conflicts with a legal or contractual retention requirement, record the reason and restrict access.

## 10. Suspected exposure response card

If data is seen, copied, released, or a device is sold before clearance:

### Contain

- stop processing and sale;
- isolate the physical device and any affected files/accounts;
- revoke any operator access or marketplace listing;
- preserve logs and the minimum evidence needed to investigate;
- do not wipe the only evidence before the incident is assessed.

## Assess

- what device/media and data were involved;
- whose information may be affected;
- whether the data was accessed, disclosed, lost or merely present;
- who may have received it and when;
- likely harm and whether remedial action can prevent it;
- whether the Privacy Act/NDB scheme, a contract, customer requirement or another law applies.

## Notify/escalate

- contact the designated privacy/incident lead and the affected owner organisation immediately;
- obtain legal/privacy advice;
- if the entity is covered and the incident is an eligible data breach, follow OAIC notification requirements;
- consider account resets, remote wipe, credit monitoring or other owner-directed remediation;
- do not promise “no data was accessed” without evidence.

## Review

- record root cause and response timeline;
- correct the intake or sanitisation control;
- retrain helpers and test the revised process;
- retain the incident record under the agreed retention policy.

## 11. Bench validation plan

Before public intake, validate the workflow with non-sensitive devices or purpose-wiped test media:

1. one working SATA HDD;
2. one working SATA SSD;
3. one NVMe SSD;
4. one removable SD/USB device;
5. one iPhone/iPad or Mac test device with a volunteer owner who performs account removal;
6. one Android device with a volunteer owner who removes the account;
7. one Windows device with a simulated clean OOBE and, if available, an organisation administrator demonstrating Autopilot removal;
8. one router/NAS/printer or smart device with test credentials and logs.

For each, time intake, identity check, media identification, sanitisation, verification and evidence creation. Record failure points. Never use real donor data to prove that the process works.

Success criteria:

- no passwords entered into the operator's records;
- no unknown device joined to the home network;
- a second reviewer can match the certificate to the asset without seeing sensitive identifiers;
- a clean setup test confirms account/tenant lock state where applicable;

- failed media reaches the documented destruction/referral route;
- the deletion/retention procedure removes test evidence without leaving uncontrolled copies.

## 12. Open questions that require professional or partner confirmation

- Is the proposed activity covered by the Privacy Act in the intended business structure or through a customer contract?
- What records must be retained for ACL, tax, insurance, downstream, grant and B2B purposes?
- What sanitisation method and certificate wording does each prospective business/school customer require?
- Will the insurer cover powered testing, charging, disassembly, soldering, customer visits and lithium-battery quarantine in the actual shed/premises?
- Which local provider can destroy failed drives and issue a usable custody/destruction record?
- What are the fire/WHs requirements for damaged batteries, toner, CRTs, soldering and chemical storage?
- Does the chosen inventory tool encrypt data at rest, support access logs, export and secure deletion?
- What happens when a donor cannot remove a lock but insists the device is theirs?
- What is the approved remedy if a downstream partner rejects a device after data clearance?

## 13. Recommended policy wording

Use this as a draft for adviser review:

We do not accept or record passwords. The owner or authorised administrator must remove accounts, device-management enrolment and ownership locks before the item can be released for reuse. We record only the result and the evidence reference. Devices containing unknown or sensitive data are held separately until an approved sanitisation or destruction route is complete. A factory reset is not represented as high-assurance sanitisation. If we discover or suspect personal information exposure, we stop work, contain the item, notify the designated contact and follow the applicable breach-response process.

This is a control draft, not legal advice. Have the actual intake form, owner declaration, certificate, listing language, privacy notice and incident plan reviewed together.

## Sources consulted

- ACSC: How to dispose of your device securely (<https://www.cyber.gov.au/protect-yourself/securing-your-devices/how-secure-your-device/how-dispose-your-device-securely>)
- ACSC: Small Business Cyber Security Guide ([https://www.cyber.gov.au/sites/default/files/2023-07/acsc\\_small\\_business\\_cyber\\_security\\_guide.pdf](https://www.cyber.gov.au/sites/default/files/2023-07/acsc_small_business_cyber_security_guide.pdf))
- NIST: SP 800-88 Rev. 2 (<https://csrc.nist.gov/pubs/sp/800/88/r2/final>)
- OAIC: APP 11 security of personal information (<https://www.oaic.gov.au/privacy/australian-privacy-principles/australian-privacy-principles-guidelines/chapter-11-app-11-security-of-personal-information>)
- OAIC: Small business (<https://www.oaic.gov.au/privacy/privacy-guidance-for-organisations-and-government-agencies/organisations/small-business>)
- OAIC: Data breach response (<https://www.oaic.gov.au/privacy/notifiable-data-breaches/preventing-preparing-for-and-responding-to-data-breaches/data-breach-preparation-and-response/part-3-responding-to-data-breaches-four-key-steps>)
- OAIC: NDB scheme (<https://www.oaic.gov.au/privacy/notifiable-data-breaches/preventing-preparing-for-and-responding-to-data-breaches/data-breach-preparation-and-response/part-4-notifiable-data-breach-ndb-scheme>)
- Apple: Remove Activation Lock (<https://support.apple.com/en-ie/108934>)
- Apple: Remove a device from Find My (<https://support.apple.com/en-mide/guide/iphone/ipha94b7686e/ios>)

- Microsoft: Windows Autopilot registration overview (<https://learn.microsoft.com/en-us/autopilot/registration-overview>)
- Microsoft: Remove Windows Autopilot device association (<https://learn.microsoft.com/en-us/autopilot/device-preparation/device-association/remove-association>)